

# ENTERPRISE ACCESS FOUNDATION

## Phase 1.5 Test Coverage Review

Existing 33-Test Suite vs. Frozen Architecture Invariants

*Review date: 17 September 2026*

## 1. Executive Verdict

The current Access test suite is a strong Phase 1.5 foundation, but it is not yet sufficient to prove all frozen security invariants. The existing suite contains 33 discovered tests: 25 domain/architecture/application cases and 8 PostgreSQL Testcontainers cases. It already covers ActionKey validation, PermissionSet relation validation, role/assignment domain rules, basic TenantAccessState behavior, module boundaries, authorization allow/deny paths, Authorize/ResolveAccessScope owner equivalence, read-side RLS, bootstrap, and a multi-step grant/revoke/idempotency scenario.

### Review decision

Do not reject the implementation. Keep the 33 tests, but add a focused security-completeness pack before Phase 1.5 is treated as fully proven.

## 2. Source Basis and Review Boundary

This review is grounded in the supplied test-scenario document for tests/Access.Tests. Statements about what is currently tested come directly from that document. Items labeled as gaps or recommended tests are reviewer findings against the previously frozen Phase 1.5 architecture.

| Source-derived fact                               | Evidence in supplied test document                                                |
|---------------------------------------------------|-----------------------------------------------------------------------------------|
| 33 tests discovered                               | 33/33 discovery confirmed; 25 non-container cases + 8 PostgreSQL container cases. |
| RLS tested with unprivileged runtime role         | Cross-tenant role read and missing-tenant-context fail-closed scenarios.          |
| Authorize / ResolveAccessScope equivalence exists | Two owner-relation cases: owned and not-owned.                                    |
| Idempotency ordering has one end-to-end scenario  | Grant, replay, key reuse, revoke, then unauthorized new grant.                    |
| TenantAccessState has domain-only revision tests  | Initialize at zero and manual BumpRevision monotonicity.                          |

## 3. What the Current 33 Tests Cover Well

| Area                              | Assessment                                                                                                    |
|-----------------------------------|---------------------------------------------------------------------------------------------------------------|
| ActionKey grammar                 | Valid keys, lowercase/segment rules, malformed keys and underscore support are tested.                        |
| PermissionSet grant validation    | Duplicate action grants and unsupported relation values are rejected.                                         |
| Role invariants                   | Origin validation and non-null tenant behavior are covered.                                                   |
| RoleAssignment domain behavior    | Revocation timing, active-at logic and source validation are covered.                                         |
| Module boundaries                 | Access does not depend on CRM/MasterData/Organization/TenantLifecycle; Domain does not depend on Persistence. |
| Default-deny paths                | Unregistered actions and unrecognized principals are denied.                                                  |
| Owner vs unrestricted grants      | Owner relation denies foreign-owned resource; unrestricted grant ignores resource owner.                      |
| Query/single-resource equivalence | Owner-based Allow/Deny and scope inclusion are tested together.                                               |
| Read-side RLS                     | A runtime role cannot see another tenant's Role; missing tenant context returns no rows.                      |
| Bootstrap/idempotency             | Bootstrap uniqueness and one evidence/outbox assertion exist; grant/revoke flow tests replay and key reuse.   |

## 4. Critical Coverage Gaps

| ID | Gap                                     | Why it matters                                                                                                                 | Priority |
|----|-----------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|----------|
| C1 | AccessScope.None is not directly proven | A recognized principal/action combination with no applicable grant should resolve to None and deny individual-resource access. | CRITICAL |

| ID  | Gap                                                                      | Why it matters                                                                                                                                                           | Priority |
|-----|--------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| C2  | AccessScope.All is not directly proven                                   | An unrestricted grant should produce All in ResolveAccessScope, not only Allow in Authorize.                                                                             | CRITICAL |
| C3  | Application-level cross-tenant deny is not explicit                      | RLS is defense-in-depth; the Access authorizer itself should fail closed when actor tenant and resource tenant differ.                                                   | CRITICAL |
| C4  | Tenant-safe RoleAssignment FK is not proven                              | A tenant A assignment must not be able to reference a tenant B role. This should fail at real PostgreSQL constraint level.                                               | CRITICAL |
| C5  | RLS write paths are not tested                                           | Existing RLS tests cover reads only. Cross-tenant INSERT/UPDATE/DELETE must be rejected by WITH CHECK / policy enforcement.                                              | CRITICAL |
| C6  | Future/expired/revoked assignment is not tested through AccessAuthorizer | Domain IsActiveAt exists, but the actual authorization evaluator must prove that inactive assignments cannot authorize.                                                  | CRITICAL |
| C7  | TenantAccessRevision is not coupled to real mutations                    | Manual BumpRevision works, but Grant/Revoke handlers must prove that effective access changes increment the tenant-wide revision.                                        | CRITICAL |
| C8  | Replay/failed command revision stability is unproven                     | Idempotent replay and denied/failed mutations must not increment TenantAccessRevision.                                                                                   | CRITICAL |
| C9  | Old successful replay after permission revocation is not tested          | The current flow tests a new grant after revoke. It does not prove that the same old successful request + same idempotency key cannot replay after authority is removed. | CRITICAL |
| C10 | Grant/Revoke exactly-once evidence/outbox is not proven                  | Bootstrap checks one evidence + one outbox, but normal grant/revoke and replay duplication semantics are not asserted.                                                   | CRITICAL |

## 5. High-Priority Additional Gaps

| ID | Gap                                    | Expected assurance                                                                                                                   |
|----|----------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------|
| H1 | Tenant-scoped uniqueness               | Same role/permission-set name or code should fail within a tenant but be allowed across different tenants.                           |
| H2 | Optimistic concurrency                 | row_version default and concurrent configuration update conflict are not directly tested.                                            |
| H3 | Recognized principal with no grant     | Distinguish principal_not_recognized from no_matching_grant for an existing principal that has no effective authorization.           |
| H4 | Additive grant algebra                 | Multiple applicable grants should compose additively without accidental replacement.                                                 |
| H5 | Reverse module-boundary direction      | Business modules should not reference Access implementation/persistence directly; they should depend on Contracts.                   |
| H6 | Network scope removal regression guard | The frozen model says Network is not an ordinary RoleAssignment scope; a test should prevent legacy scope semantics from returning.  |
| H7 | CREATE action with type-only resource  | Authorization contract must support create operations before a resource ID exists.                                                   |
| H8 | System template provisioning semantics | If bootstrap provisions platform templates to tenant-local instances, prove tenant_id is set and no runtime global role is produced. |
| H9 | Idempotency identity binding           | The same key should not be reusable across a different tenant/principal/action context even if the payload is otherwise similar.     |

## 6. TenantAccessRevision - Most Important Missing Proof

The current suite proves only that a new TenantAccessState starts at revision 0 and that manually calling BumpRevision increments monotonically. That is necessary but not sufficient. The architecture defines TenantAccessRevision as the single tenant-wide authorization epoch, so handler-level tests must prove when it changes and when it does not.

| Operation                                         | Expected revision behavior                                                           |
|---------------------------------------------------|--------------------------------------------------------------------------------------|
| Bootstrap initial snapshot                        | May remain 0 if provisioning defines the initial baseline; this must be intentional. |
| Successful new role assignment grant              | Revision increments exactly once.                                                    |
| Successful revoke                                 | Revision increments exactly once.                                                    |
| Idempotent replay of already-applied grant/revoke | Revision does not increment.                                                         |
| Authorization-denied mutation                     | Revision does not increment.                                                         |
| Validation failure / idempotency key misuse       | Revision does not increment.                                                         |

### Acceptance invariant

TenantAccessRevision changes only when the tenant's effective authorization state changes. row\_version remains a separate optimistic-concurrency mechanism.

## 7. RLS Coverage - Current Strength and Missing Write Assurance

The current tests correctly use an unprivileged runtime database role and verify cross-tenant read isolation plus fail-closed behavior when app.tenant\_id is absent. The remaining gap is write-side assurance.

- Cross-tenant INSERT must fail.
- Cross-tenant UPDATE must fail.
- Cross-tenant DELETE must fail or be impossible through the policy model.
- At least one representative tenant-safe composite relationship must reject a tenant A child pointing to a tenant B parent.
- Representative RLS coverage should include more than Roles - especially RoleAssignment and TenantAccessState, because those records directly influence effective authorization.

## 8. Idempotency Security Gap

The existing five-stage Grant/Revoke test is valuable because it proves authorization happens before the idempotency layer for a new unauthorized request. However, it does not test the more dangerous replay case where an old successful protected response already exists.

| Step | Scenario                                     | Expected result                                    |
|------|----------------------------------------------|----------------------------------------------------|
| 1    | Authorized admin sends Request X with key K  | Success; response stored.                          |
| 2    | Admin's relevant authority is revoked        | Authorization state changes.                       |
| 3    | Same Request X with same key K is sent again | Current authorization is evaluated before replay.  |
| 4    | Authorization now fails                      | Old success is NOT returned; request fails closed. |

### Frozen principle

Idempotency is a reliability mechanism, never an authorization bypass.

## 9. Recommended Minimum Test Pack Before Final Acceptance

1. ResolveAccessScope\_returns\_None\_when\_no\_effective\_grant
2. ResolveAccessScope\_returns\_All\_for\_unrestricted\_grant
3. Authorizer\_denies\_cross\_tenant\_resource\_even\_before\_RLS
4. RoleAssignment\_rejects\_cross\_tenant\_role\_reference
5. Runtime\_RLS\_rejects\_cross\_tenant\_write
6. Future\_expired\_and\_revoked\_assignments\_do\_not\_authorize
7. Grant\_and\_revoke\_increment\_TenantAccessRevision\_exactly\_once
8. Replay\_and\_failed\_mutations\_do\_not\_increment\_TenantAccessRevision
9. Previously\_successful\_idempotent\_request\_cannot\_replay\_after\_authority\_revocation
10. Grant\_and\_revoke\_emit\_exactly\_once\_evidence\_and\_outbox\_records

## 10. Recommended Secondary Test Pack

11. Same role/permission-set key is rejected within one tenant but allowed in another tenant.
12. row\_version starts at the expected baseline and concurrent update produces the expected conflict behavior.
13. Recognized principal with no assignment/grant returns no\_matching\_grant rather than principal\_not\_recognized.
14. Multiple grants compose additively.
15. CRM/Sales/MasterData do not reference Access implementation/persistence directly.
16. Legacy Network assignment scope cannot be created or resolved.
17. CREATE authorization supports a type-only resource descriptor with no entity ID.
18. Tenant-local system-template provisioning produces tenant-owned instances without continuous reconciliation.
19. Idempotency key is context-bound to tenant + principal/acting-for + action + request fingerprint.

## 11. Existing Multi-Stage Integration Test - Refactoring Recommendation

Keep the current end-to-end GrantRevokeRoleAssignmentHandlerTests scenario because it is a useful workflow test. But do not rely on it as the only proof of each security rule. Because all five stages live in one test, an early failure can prevent later security assertions from executing.

Recommendation: retain the end-to-end scenario and add smaller independent tests for authorization-before-replay, idempotency key misuse, revoke behavior, revision changes, and exactly-once evidence/outbox.

## 12. Acceptance Gate

| Gate               | Required before Phase 1.5 is considered fully proven                                                                                         |
|--------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| Existing suite     | 33/33 remains green.                                                                                                                         |
| Critical additions | All 10 critical tests above are implemented and green.                                                                                       |
| RLS                | Read + write + no-context + tenant-safe relationship negative tests pass on real PostgreSQL.                                                 |
| Revision           | TenantAccessRevision mutation/no-op semantics are explicitly tested.                                                                         |
| Idempotency        | Same-key replay after authority revocation fails closed.                                                                                     |
| Evidence/outbox    | Grant/revoke and replay semantics prove exactly-once behavior.                                                                               |
| Architecture       | Both dependency directions are guarded: Access does not depend on business modules; business modules do not depend on Access implementation. |
| Full solution      | Complete repository test suite remains green after additions.                                                                                |

## 13. Final Assessment

The present 33-test suite should be preserved. It demonstrates that Claude implemented a substantial portion of the intended Access foundation correctly, especially basic default-deny behavior, owner-relation semantics, query/single-resource consistency, unprivileged PostgreSQL RLS, bootstrap and idempotency ordering.

The remaining issue is completeness, not direction. The largest risks are authorization state revision behavior, write-side tenant isolation, tenant-safe relational integrity, inactive-assignment handling, and replay of previously successful protected requests after authority revocation.

### Final reviewer verdict

33/33 green is not yet sufficient to declare the security foundation fully proven. Add the 10-test critical pack first; the secondary pack should follow before Phase 2 authorization becomes widely consumed.

## 14. Source Note

Primary supplied source: 'Enterprise Access Foundation - Test Senaryolari ve Beklenen Sonuclar' (tests/Access.Tests), dated 17 September 2026. Reviewer recommendations in this report are derived by comparing that test inventory with the frozen Phase 1.5 architecture decisions.